

UNITED ACCREDITATION FOUNDATION



Document Name	ACCREDITATION REQUIREMENTS FOR CERTIFICATION OF INFORMATION SECURITY MANAGEMENT SYSTEMS (ISMS)
Document Number	UAF-CAB-ISMS
Applicable For	APPLICABLE TO ALL CERTIFICATION BODIES APPLYING FOR OR HOLDING ACCREDITATION FOR ISMS
Revision Number	V02
Revision Date	MAR-10-2026
Effective Date	MAR-10-2026



**ACCREDITATION REQUIREMENTS FOR
CERTIFICATION OF INFORMATION SECURITY
MANAGEMENT SYSTEMS (ISMS)**

Doc. No.: UAF-CAB-ISMS
Rev. No.: V02
Effective Dt: MAR-10-2026

Contents

1. ACCREDITATION REQUIREMENTS	3
2. ADDITIONAL DOCUMENTS	3
3. UAF DOCUMENTS APPLICABLE FOR ACCREDITATION OF ISO/IEC 27001 CERTIFICATION	3
4. CERTIFICATION DOCUMENTS	4
5. SCOPE OF ACCREDITATION	4
6. REQUIREMENTS	4
7. RESOURCE REQUIREMENTS	4
8. INFORMATION REQUIREMENTS.....	5
9. PROCESS REQUIREMENTS	5
10. MANAGEMENT SYSTEM REQUIREMENTS FOR CERTIFICATION BODIES.....	5
11. ACCREDITATION ASSESSMENTS.....	5
12. ASSESSMENTS	6
13. INITIAL ASSESSMENTS	6
14. WITNESS ASSESSMENTS.....	6
15. SURVEILLANCE AND REASSESSMENTS	7

1. ACCREDITATION REQUIREMENTS

This scheme document establishes additional scheme-specific accreditation requirements applicable to certification bodies performing certification against the applicable management system standard covered under this scheme. These requirements supplement the applicable accreditation standards, including UAF-GEN-CAB-01 — General Accreditation Requirements and UAF-GEN-CAB-02 — General Rules and Conditions for Use of UAF Accreditation Mark, together with other applicable international mandatory documents and normative references identified in this document.

Accreditation of Certification Bodies under this scheme shall be granted and maintained in accordance with the following requirements:

- ISO/IEC 17021-1 — Conformity assessment — Requirements for bodies providing audit and certification of management systems.
- UAF-GEN-CAB-01 — General Accreditation Requirements.
- UAF-GEN-CAB-02 — General Rules and Conditions for Use of UAF Accreditation Mark.
- Applicable IAF/GACI Mandatory Documents and other normative documents referenced in this scheme document.

In case of any ambiguity, difference in interpretation, or lack of clarity between this scheme document and other applicable UAF accreditation documents and policies, clarification shall be obtained from UAF. The interpretation or guidance provided by UAF shall be considered final for the purposes of accreditation.

2. ADDITIONAL DOCUMENTS

ISO/IEC, IAF/GACI and other applicable requirements applicable for accreditation of ISO/IEC 27001 certification:

- ISO/IEC 27006-1:2024 Information security, cybersecurity and privacy protection – Requirements for bodies providing audit and certification of Information Security Management Systems – Part 1: General
- IAF MD 1 IAF Mandatory Document for the Audit and Certification of a Management System Operated by a Multi-Site Organization
- IAF MD 2 IAF Mandatory Document for the Transfer of Accredited Certification of Management Systems.
- IAF MD 4 IAF Mandatory Document for the Use of Information and Communication Technology (ICT) for Auditing/Assessment Purposes
- IAF MD 11 IAF Mandatory Document for Application of ISO/IEC 17021 for Audits of Integrated Management Systems (IMS)
- IAF MD 23 Control of Entities Operating on Behalf of Accredited Management Systems Certification Bodies
- IAF MD 28 IAF Mandatory Document for the Upload and Maintenance of Data on IAF Database

3. UAF DOCUMENTS APPLICABLE FOR ACCREDITATION OF ISO/IEC 27001 CERTIFICATION

- UAF-GEN-CAB-01-General Accreditation requirements
- UAF-GEN-CAB-02-Conditions for the use of UAF Symbol
- UAF-PL:2014-01: Policy on Providing Certification Activities in Foreign Countries Where Regulatory Approval or Authorization is Required.



**ACCREDITATION REQUIREMENTS FOR
CERTIFICATION OF INFORMATION SECURITY
MANAGEMENT SYSTEMS (ISMS)**

Doc. No.: UAF-CAB-ISMS
Rev. No.: V02
Effective Dt: MAR-10-2026

- UAF F-31A-Annexure A- Guidance for the addition of countries, locations and critical Locations.
- UAF-PL:2016-06: UAF Policy for the Collection of Data to Provide Indicators of Management System Certification Bodies' Performance as per IAF MD 15:2014.
- UAF-PL:2018-04: UAF Policy on handling misconduct & unethical practices in the certification process.
- UAF-PL:2019-07-01: UAF Policy on accreditation scopes & witnessing activities for accreditation of management system CBs.
- UAF-PL:2019-07-02: UAF Policy regarding general administration.
- UAF-PL:2020-03-02: UAF Policy for handling extraordinary events or circumstances affecting UAF Accredited CABs on their certified clients/persons.
- UAF-PL:2020-03-03: UAF Policy on Remote Assessment.
- UAF-PL:2023-09-01: UAF Policy for CAB operations in Sanctioned Countries.
- UAF-PL:2024-02-01: UAF policy regarding the consideration of climate change within the organizational context of the management system.

4. CERTIFICATION DOCUMENTS

Certification Bodies certifying management systems in accordance with ISO/IEC 27001 — Information security, cybersecurity and privacy protection — Information Security Management Systems — Requirements.

5. SCOPE OF ACCREDITATION

Certification of Information Security Management Systems (ISMS) Accreditation provided in accordance with ISO/IEC 27006-1.

6. REQUIREMENTS

6.1 General

6.1.1 Legal And Contractual Matters

The requirements of ISO/IEC 17021-1:2015, Clause 5.1 apply.

6.1.2 Management Of Impartiality

The requirements of ISO/IEC 17021-1:2015, Clause 5.2 apply. In addition, the ISMS specific requirements and guidance apply as detailed in ISO/IEC 27006-1.

6.1.3 Liability And Financing

The requirements of ISO/IEC 17021-1:2015, Clause 5.3 apply.

6.2 Structural Requirements

The requirements of ISO/IEC 17021-1:2015, Clause 6 apply.

7. RESOURCE REQUIREMENTS

7.1 Competence of management and personnel

The requirements of ISO/IEC 17021-1:2015, Clause 7.1 apply and in addition, the ISMS specific requirements and guidance apply as detailed in ISO/IEC 27006-1.

7.2 Personnel involved in the certification activities

The requirements of ISO/IEC 17021-1:2015, Clause 7.2 apply and in addition, the ISMS specific requirements and guidance apply as detailed in ISO/IEC 27006-1.

7.3 Use of individual external auditors and external technical experts

The requirements of ISO/IEC 17021-1:2015, Clause 7.3 apply and in addition, the ISMS specific requirements and guidance apply as detailed in ISO/IEC 27006-1.

8. INFORMATION REQUIREMENTS

8.1 Publicly accessible information

The requirements of ISO/IEC 17021-1:2015, Clause 8.1 apply.

8.2 Certification documents

The requirements of ISO/IEC 17021-1:2015, Clause 8.2 apply and in addition, the ISMS specific requirements and guidance apply as detailed in ISO/IEC 27006-1.

8.3 Reference to certification and use of marks

The requirements of ISO/IEC 17021-1:2015, Clause 8.3 apply.

8.4 Confidentiality

The requirements of ISO/IEC 17021-1:2015, Clause 8.4 apply and in addition, the ISMS specific requirements and guidance apply as detailed in ISO/IEC 27006-1.

8.5 Information exchange between a certification body and its clients

The requirements of ISO/IEC 17021-1:2015, Clause 8.5 apply.

9. PROCESS REQUIREMENTS

The requirements of ISO/IEC 17021-1:2015, Clause 9 apply and in addition, the ISMS specific requirements and guidance apply as detailed in ISO/IEC 27006-1.

10. MANAGEMENT SYSTEM REQUIREMENTS FOR CERTIFICATION BODIES

The requirements of ISO/IEC 17021-1:2015, Clause 10 apply. In addition, the ISMS-specific requirements and guidance apply as detailed in ISO/IEC 27006-1.

11. ACCREDITATION ASSESSMENTS

The accreditation assessment depends upon the following factors:

- Key locations and other operational non-key locations.
- Countries in which UAF-accredited certificates may be issued.
- Existing accreditation by other Accreditation Bodies.
- Other certification or conformity assessment activities carried out by the Certification Body
- Other relevant details provided in the application.

12. ASSESSMENTS

- a. Document Review
- b. Initial Office Assessments
- c. Witness Assessments.
- d. Remote Assessments
- e. Scope Verifications during extraordinary circumstances

13. INITIAL ASSESSMENTS

The assessment extent and content depend on the requested scope of accreditation, the other activities for which the body is accredited or requests accreditation and the performance of the body at previous assessments.

The assessment consists of the following activities:

- Document Review
- Office assessment
- Witness Assessments
- Scope Verifications during extraordinary circumstances.

14. WITNESS ASSESSMENTS

The Certification Body (CB) shall be subject to witness assessment of its ISO/IEC 27001 certification activities as part of initial accreditation or extension of scope. At least one witness assessment shall be conducted.

Generally, at least two weeks prior to the witness assessment, the CB shall provide UAF with the following information and records:

- a. Records of the CB's contract review for the selected organization, including qualification and competence records of the auditors and technical experts assigned.
- b. A copy of the ISO/IEC 27001 certificate issued by the CB, where a surveillance or recertification audit is to be witnessed.
- c. Where the CB is already accredited by an IAF Full Member Accreditation Body, previous witness assessment reports may be considered subject to review. In such cases, UAF may verify the authenticity and validity of the witness reports directly with the issuing Accreditation Body. This verification is procedural in nature and does not imply any concern regarding the CB's operations or prior assessments.
- d. The report of the CB's document review, pre-assessment or readiness assessment (or the most recent assessment report), together with the audit plan.

In addition to the general criteria for selection of audits to be witnessed, UAF may also consider the following:

- a. UAF will normally avoid witnessing auditors who have already been witnessed for the same scheme.
- b. UAF will normally avoid witnessing audits at the same organization.
- c. UAF will review the CB's audit report as part of the witness assessment.
- d. To enable selection of audits for witnessing, the CB shall, upon request, provide audit planning information for a defined period. This information shall include, as a minimum:
 - Type of audit (initial, surveillance, or recertification)
 - Name and address of the auditee
 - Audit standard(s)



**ACCREDITATION REQUIREMENTS FOR
CERTIFICATION OF INFORMATION SECURITY
MANAGEMENT SYSTEMS (ISMS)**

Doc. No.: UAF-CAB-ISMS
Rev. No.: V02
Effective Dt: MAR-10-2026

- Scope of certification
- Names of auditor(s) and technical expert(s)
- Date(s) of the audit

15. SURVEILLANCE AND REASSESSMENTS

The surveillance assessments of the Certification Body's ISO/IEC 27001 certification activities shall normally be conducted annually or as defined in the assessment program, or earlier where justified by the assessment team based on identified risks, changes, or performance concerns. The duration and scope of surveillance assessments shall be determined through a risk-based assessment program, considering the volume, complexity, and maturity of the ISO/IEC 27001 certification activities.

The number and type of witness assessments during surveillance shall be determined in accordance with the assessment program in line with accreditation standard requirements and UAF-PL:2019-07-01 — UAF Policy on accreditation scopes & witnessing activities for accreditation of management system CB. Witnessing decisions and number of witnesses may vary considering the outcomes of certification file reviews, sector complexity, use of technical experts, and changes to personnel or processes.

During each surveillance assessment, UAF shall verify the continued effective implementation of the ISO/IEC 27001 certification scheme, including compliance with ISO/IEC 27006-1 and applicable accreditation requirements.

Certification files reviewed during surveillance and reassessment shall be selected using a risk-based sampling methodology. The sampling approach may consider:

- Number of ISO/IEC 27001 certificates issued since the previous assessment
- Organization size, complexity and other factors
- Levels of risk
- Information security exposure
- Use of ICT or remote assessment techniques
- Previous nonconformities or complaints

The number of files selected may be increased where higher risk is identified. This is approximately one quarter of the square root of the number of certificates, with a maximum of 18 files and a minimum of one file. The number of files to be reviewed may increase depending on risk-based parameters detailed in the assessment program.

Where applicable, witness assessments may be planned to cover multiple schemes (e.g. combined audits with other standards), provided that it ensures adequate coverage of ISO/IEC 27001-specific competence and assessment objectives.

Applying the above guidelines shall consider whether witness assessments may serve multiple schemes (e.g. through witnessing combined audits) and how such witness assessments are performed in other schemes. The accreditation cycle will be for four years, and the reaccreditation assessment should be carried out at least four months before the accreditation expiry. The assessment plan will be listed in the assessment program and updated as required.